

Entitlements / access design (3 security-group cases)

Group: devops-prod
READ-ONLY standing in PROD

JIT break-glass (PROD write)
emergency / release / change
only

request

Approver = PRODUCT
OWNER
(distinct identity, no self-
approval)

approve, time-bound STS +
MFA

Temporary PROD write
auto-expires

Group: developers
FULL in DEV · ZERO in
UAT/PROD

Immutable blockchain / hash-
chained ledger
who · when · why · approver ·
expiry
(mirrored to auth.log)

Group: uat-preprod
DEV devs reach UAT: read-
biased,
pipeline-only deploy, no manual
mutation

Version control & promotion

Git (private repo ugly/insucar)
PR + review + change ticket

Jenkins CI: build+test+scan ->
Kaniko -> ECR

Spinnaker CD pipeline (gated)

dev-tier only

read/pipeline

read-only

write during window

Environments (isolation) — design: separate AWS accounts

DEV
free iteration

Spinnaker: manual judgment

UAT (pre-production)
== prod config

manual judgment (PRODUCT
OWNER)

PRODUCTION
read-only by default

Cross-cutting security

Separate accounts / IAM / KMS
/ secrets per tier

RLS multi-tenant isolation
(tenant_id)

Rust vault: PII tokenization,
mTLS-only, isolated

Hidden operator surface · MFA
· zero-trust

Secrets in AWS Secrets
Manager (no secrets in code)